

Toward Legible Cyber Governance

The Case for Harmonized Frameworks

Author: Amy

Date: May 2026

Series: Hollow House Institute Policy Paper

Distribution: Zenodo | GitHub | LinkedIn

DOI: 10.5281/zenodo.XXXXXXX [placeholder — assign upon upload]

Abstract

Cyber governance is failing not because the rules are wrong, but because they are illegible across jurisdictions. Organizations operating across borders must simultaneously satisfy NIS2, CIRCIA, the UK Cyber Essentials Plus scheme, Singapore's Cybersecurity Act, and multiple sector-specific overlays — each with different reporting timelines, divergent definitions of critical infrastructure, and incompatible audit architectures. The result is not improved security; it is compliance theater. This paper argues that the solution is not a unified global rulebook — decades of failed harmonization attempts confirm that ambition is unrealistic — but legibility: governance frameworks that can read each other's conclusions, translate incident reports across channels, and allow a single evidence base to satisfy multiple regulators simultaneously. We survey the current landscape of cyber governance instruments, diagnose fragmentation as a structural product of three incompatible regulatory traditions, and define legibility precisely as a technical governance concept. We then

examine precedents where cross-framework interoperability has been achieved — financial services, aviation safety, and pharmaceutical regulation — and identify what cyber governance has failed to replicate. Finally, we propose a concrete, phased pathway from the present state toward a legible ecosystem, anchored in near-term taxonomy alignment, medium-term federated incident reporting, and the long-term creation of a narrow multilateral clearing mechanism. Without legibility, everyone will continue complying and nobody will be safer.

Table of Contents

1. The Problem Is Legibility, Not Law	3
2. The Current Landscape: An Honest Survey	4
2.1 International Treaties and Norms Processes	
2.2 Regional and National Frameworks	
2.3 Voluntary Standards and Sector Overlays	
3. Why Fragmentation Is Structural, Not Accidental	6
4. What Legibility Actually Means in Practice	8
5. Existing Precedents That Work — and Why	9
6. A Practical Pathway Toward Legibility	11
6.1 Phase I (1–3 Years): Common Taxonomy and Mutual Recognition Pilots	
6.2 Phase II (3–7 Years): Federated Infrastructure and Expanded Recognition	
6.3 Phase III (7+ Years): A Narrow Multilateral Clearing Mechanism	
7. Recommendations	13
8. Conclusion: Security Improves When Information Flows	14

1. The Problem Is Legibility, Not Law

Suppose you are the Chief Information Security Officer of a multinational firm with operations in Frankfurt, Houston, London, and Singapore. You operate cloud infrastructure, serve customers across all four jurisdictions, and your systems touch payment processing and logistics — sectors that most governments would classify as critical infrastructure under at least some applicable definition. Your legal team has handed you a compliance matrix and the list is formidable: the European Union's NIS2 Directive, now in full force following the October 2024 transposition deadline; the Cyber Incident Reporting for Critical Infrastructure Act (CIRCI) in the United States, whose rulemaking is progressing through CISA; the UK's Cyber Essentials Plus certification scheme and the National Cyber Security Centre's broader guidance architecture; and Singapore's Cybersecurity Act, most recently amended in May 2024 to extend obligations to supply chains and new categories of regulated entities. On top of those sit sector-specific overlays: the SWIFT Customer Security Controls Framework if you touch payment messaging, and IEC 62443 if any of your logistics infrastructure qualifies as an industrial control system. None of these instruments share a common definition of "significant incident." None of them have agreed reporting timelines — NIS2 demands an early warning within 24 hours and a full incident notification within 72 hours, while CIRCI requires reporting of covered cyber incidents within 72 hours of the organization's reasonable belief that an incident has occurred and ransom payments within 24 hours of payment. The UK and Singapore frameworks have their own clocks and their own notification pathways. None of them recognize each other's audit conclusions. An ISO 27001 certification — the closest thing the field has to a universal credential — satisfies none of them in full, and satisfies most of them only partially and implicitly.

The question worth asking is not whether this organization is compliant. It probably is, or is trying to be. The question is whether it is more *secure* for having navigated all of this. The answer, almost certainly, is marginally — but not proportionate to the effort. And the second question is whether the collective security picture is clearer to any of the regulators involved. Here the answer is plainly no. Each regulator receives a report formatted for its own system. No regulator sees the whole picture. Incident signals that might reveal a cross-border campaign are siloed inside national reporting channels. The intelligence value of the data being collected is systematically destroyed by the architecture that collects it.

That is a legibility failure. The frameworks are not, individually, unreasonable. Most of them reflect genuine thinking about how organizations should manage cyber risk. The problem is that they cannot read each other. They were not designed to. And the organizations caught in the middle are spending enormous resources producing compliance artifacts that do not aggregate into anything useful for anyone — including the organizations producing them.

This paper argues that the right response to this situation is not to write a new global treaty, convene another UN working group, or attempt to merge the EU and US approaches into a single instrument. None of those paths are realistic in a near-term timeframe, and the last decade of attempts provides substantial evidence that they are not even particularly desirable — different legal traditions, threat environments, and political economies produce legitimately different governance choices. What is both realistic and urgently needed is *legibility*: a set of architectural properties that allow governance frameworks to interoperate without requiring them to be identical. The case for that concept, and a practical pathway to achieve it, is what follows.

2. The Current Landscape: An Honest Survey

2.1 International Treaties and Norms Processes

The foundational international instrument in this space is the Budapest Convention on Cybercrime, opened for signature in 2001 and now ratified by 68 states. The Convention's contribution was real: it established the first multilateral legal framework for criminalizing unauthorized computer access, data interference, and system interference, and it created a mutual legal assistance architecture that remains the primary formal channel for cross-border law enforcement cooperation in cyber cases. But the Budapest Convention was drafted at a moment when the dominant cyber threat model was the individual hacker. It was not designed for the state-sponsored campaigns, ransomware-as-a-service ecosystems, or critical infrastructure attacks that define the current threat environment. Its jurisdictional provisions assume territorial anchors that cloud computing and distributed infrastructure have fundamentally disrupted. The Second Additional Protocol, adopted in 2022, expanded provisions for emergency data preservation and subscriber information disclosure, but it does not resolve the fundamental tension between the Convention's territorially-grounded legal architecture and a threat environment that is structurally borderless. Significant gaps remain in addressing AI-enabled attacks, IoT vulnerabilities, and cross-border enforcement when perpetrators operate across non-signatory jurisdictions.

At the UN level, the Group of Governmental Experts (GGE) process produced its most consequential output in the 2015 report establishing eleven non-binding voluntary norms for responsible state behavior in cyberspace, including commitments not to attack critical infrastructure and to assist other states in investigating cyber incidents. The subsequent Open-Ended Working Group (OEWG) processes — broader in participation, slower in output — concluded their 2021–2025 mandate in July 2025, producing a consensus report recommending a permanent "Global Mechanism" to continue norm development. This is meaningful institutional progress. It is not, however, operational governance. The norms are non-binding, their implementation is opaque, and the verification mechanisms do not exist. The gap between the norms states have agreed to on paper and the behavior observable in practice is wide enough to drive significant geopolitical incidents through. UN-level processes matter for political legitimacy and for establishing the outer boundaries of acceptable state behavior, but they are not where operational cyber governance happens and are not, realistically, where it will happen in the medium term.

2.2 Regional and National Frameworks

The most ambitious regional governance architecture in operation is the EU's NIS2 Directive, which entered force in January 2023 and whose transposition deadline passed on 17 October 2024. NIS2 is genuinely significant. It expands the scope of its predecessor beyond digital service providers to cover entities across energy, transport, banking, financial market infrastructure, health, drinking water, wastewater, digital infrastructure, ICT service management, public administration, and space — a comprehensive definition of the sectors where systemic cyber failure would be societally catastrophic. It mandates a three-stage incident notification process: an early warning to the relevant national CSIRT within 24 hours of becoming aware of a significant incident, a full incident notification within 72 hours, and a final report within one month. It imposes minimum security measures including vulnerability handling, supply chain security assessment, and encryption policy. Maximum penalties for essential entities reach €10 million or 2% of global turnover. The European Commission adopted its first implementing regulations for digital service providers in October 2024, adding specificity to the "significant incident" threshold for cloud providers, data centers, online marketplaces, search engines, and social networking platforms.

NIS2's limitation is not its ambition but its implementation architecture. Transposition into national law has been uneven across member states — the Commission itself acknowledged in late 2024 that several states had missed the October deadline or implemented requirements in ways that diverge materially from each other. A German "significant incident" threshold is not identical to a Danish one. An audit that satisfies the competent authority in the Netherlands does not automatically satisfy one in Poland. The Directive harmonizes intent; it does not yet produce operational harmonization at the level where a CISO's compliance work in Berlin transfers cleanly to an audit in Warsaw, let alone to one in Washington or Singapore.

In the United States, CIRCIA — signed into law in March 2022 — establishes mandatory incident reporting requirements for critical infrastructure sectors. CISA published its Notice of Proposed Rulemaking in April 2024, and the final rule process is ongoing. When implemented, CIRCIA will require covered entities to report covered cyber incidents within 72 hours and ransom payments within 24 hours. It also creates a Cyber Incident Reporting Council charged with coordinating and harmonizing federal reporting requirements across agencies — a recognition, embedded in the statute itself, that the federal reporting landscape is internally fragmented. CIRCIA is an important domestic step. But its interaction with NIS2, the UK framework, and Singapore's requirements remains entirely unaddressed in its design.

In the United Kingdom, the NCSC's Cyber Essentials and Cyber Essentials Plus certification schemes provide a baseline credential anchored in five technical controls: boundary firewalls and internet gateways, secure configuration, access control, malware protection, and patch management. Cyber Essentials Plus adds independent technical verification through hands-on assessment. As of April 2026, the scheme operates under version 3.3 of its technical requirements. The scheme is effective at what it does — establishing a minimum floor for organizations that cannot sustain a full ISO 27001 program — but it is explicitly a baseline measure and is not designed to satisfy the more demanding requirements of NIS2 or CIRCIA.

UK organizations that trade in the EU or operate US infrastructure face the same dual-compliance burden as anyone else.

Singapore's Cybersecurity Act, amended in May 2024, extends oversight to supply chain relationships of Critical Information Infrastructure operators and introduces new categories of regulated entities including "foundational digital infrastructure" providers and system integrators. The amendments reflect Singapore's recognition that the original 2018 Act's perimeter was too narrow for the cloud-era threat model. The obligation to report supply chain incidents in particular aligns with NIS2's Article 21 supply chain security requirements in spirit, though not in process or timeline. Singapore's regulatory authority, the Cyber Security Agency (CSA), has been active in bilateral information sharing arrangements, but these operate at the intelligence level rather than the regulatory level.

2.3 Voluntary Standards and Sector Overlays

NIST's Cybersecurity Framework 2.0, released in February 2024, represents the most mature voluntary framework in the field. The update expanded the CSF's scope from critical infrastructure to all organizations regardless of size or sector, added a new Govern function alongside the existing Identify, Protect, Detect, Respond, and Recover functions, and introduced enhanced supply chain risk management provisions. Its cross-reference catalog maps CSF outcomes against more than fifty other standards and frameworks — the closest thing the field has to a translation layer. The CSF's limitation is structural to its design: it is deliberately voluntary, descriptive rather than prescriptive, and carries no enforcement mechanism. Its influence on practice is real and substantial, but it operates through persuasion rather than obligation, and a NIST CSF profile does not constitute evidence of compliance with any mandatory regulatory requirement.

ISO/IEC 27001:2022 is the auditable international standard for information security management systems. The 2022 revision reorganized its Annex A controls from 114 across 14 sections to 93 controls across four thematic areas and aligned with the ISO Harmonized Structure to improve coherence with other management system standards. Certification to ISO 27001 is the closest thing the field has to a universal compliance credential. Its limitation is well understood: it certifies the existence and operation of a management system, not the achievement of specific security outcomes. Two organizations with identical ISO 27001 certifications may have implemented entirely different technical controls. The standard's process orientation, while appropriate for a voluntary international standard, means that regulators with outcome-based requirements — as NIS2 increasingly is — cannot accept an ISO 27001 certificate as dispositive evidence of compliance.

In financial services, the SWIFT Customer Security Controls Framework (CSCF) defines mandatory and advisory security controls applicable to all SWIFT users, structured around protecting the SWIFT environment, managing access, and detecting anomalous activity. The framework is aligned with ISO 27002, PCI DSS, SOC 2, and NIST CSF, and requires annual independent assessment and attestation submission. IEC 62443, developed jointly by ISA and IEC and updated through ANSI/ISA-62443-2-1-2024, governs cybersecurity for industrial automation and control systems — the OT layer that underpins energy grids, water systems,

and manufacturing facilities. IEC 62443 is technically precise and sector-specific in ways that horizontal frameworks like ISO 27001 cannot be. Both the SWIFT CSCF and IEC 62443 represent sector-specific governance done relatively well. Neither connects operationally to the horizontal regulatory requirements of NIS2, CIRCIA, or the national frameworks they overlay.

3. Why Fragmentation Is Structural, Not Accidental

Accounts of cyber governance fragmentation often treat it as a coordination failure — a problem of insufficient political will, or insufficient awareness that fragmentation is harmful. That framing is mistaken, and any reform effort that adopts it will be miscalibrated. Fragmentation is not the absence of coordination; it is the product of three regulatory traditions that assembled simultaneously in the 1990s and 2000s, each with coherent internal logic and fundamentally incompatible assumptions about disclosure, jurisdiction, and accountability.

The first tradition is **national security and intelligence**. When governments first began grappling with the cyber threat to critical infrastructure in the mid-1990s — the Clinton administration's Presidential Decision Directive 63 in 1998 is a useful marker — the dominant institutional response came from the intelligence and defense communities. In that tradition, information about threats, vulnerabilities, and incidents is classified by default; disclosure is an exception requiring specific authorization; attribution is a state prerogative; and cooperation happens through liaison relationships between trusted intelligence partners operating under legal frameworks that are deliberately opaque. The instinct is protective: share too much and you reveal sources and methods, alert adversaries to what you know, or enable further exploitation of vulnerabilities you are trying to monitor. This tradition produced the ISACs (Information Sharing and Analysis Centers), which operate on a trusted-community model with strict controls on information dissemination. It also produced the deep reluctance of national security agencies to disclose incident information that might constitute evidence of adversary capability.

The second tradition is **criminal law and law enforcement**. Cyber incidents that constitute crimes — unauthorized access, fraud, extortion — fall under criminal jurisdiction, which is fundamentally territorial. Prosecutors need evidence that meets domestic admissibility standards, collected through processes authorized under domestic law. Mutual Legal Assistance Treaties (MLATs) provide the formal mechanism for cross-border evidence sharing, but they are slow, bilateral, and designed for a world where evidence has physical location. Cloud storage, content delivery networks, and distributed infrastructure mean that the data relevant to a cyber investigation may simultaneously reside in data centers in three continents, governed by conflicting legal obligations regarding disclosure and data localization. The Budapest Convention attempted to address this with its provisions on expedited preservation of data and real-time interception of traffic data, but the jurisdictional tensions have not been resolved — they have only been partially mitigated. Criminal law's territorial logic produces incident reporting obligations designed around what prosecutors need, not what regulators or defenders need.

The third tradition is **technical standards**. Standards bodies — ISO, NIST, IEC, ISA, IETF — operate on voluntary consensus, typically driven by industry participants with implementation knowledge. Their outputs are technically precise, implementation-tested, and deliberately non-prescriptive about legal obligations. The assumption embedded in the standards tradition is that organizations will adopt good practices because they provide competitive advantage or because they reduce operational risk — not because they are legally compelled. This produces frameworks that are genuinely useful for practitioners and genuinely insufficient as governance instruments, because they carry no enforcement mechanism and create no accountable obligation.

Critical Finding: The Incompatibility Is Structural

These three traditions differ on the most basic governance questions. The intelligence tradition treats disclosure as a security risk. The criminal law tradition treats disclosure as an evidentiary requirement subject to territorial jurisdiction. The technical standards tradition treats disclosure as voluntary. Any cyber governance framework must implicitly take a position on all three. When NIS2 mandates 24-hour early warnings and 72-hour full notifications, it is making a bet that transparency serves collective defense — a position the intelligence tradition resists. When CIRCIA creates liability protections for voluntary disclosures to CISA, it is trying to bridge the criminal law tradition's adversarial framing with the need for information sharing. When ISO 27001 certifies management systems rather than security outcomes, it is preserving the standards tradition's flexibility at the cost of regulatory reliance. These tensions are not resolvable by clever drafting; they require explicit political choices about which tradition governs which domain.

The consequence is that every major cyber governance instrument is, at its foundation, a compromise within or between these traditions — and those compromises are largely invisible to organizations trying to comply with multiple frameworks simultaneously. NIS2's supply chain requirements, drafted in the regulatory tradition, produce compliance obligations that are conceptually incompatible with the intelligence tradition's need to protect information about supplier vulnerabilities. CIRCIA's federal information sharing provisions, designed to aggregate incident data within the US government, do not connect to the EU's CSIRT network or Singapore's CSA, because each of those operates under a different disclosure logic inherited from a different tradition. Harmonization efforts that do not name this structural problem — that treat it as a mere coordination puzzle — will consistently undershoot.

4. What Legibility Actually Means in Practice

Definition: Legibility in Cyber Governance

A **legible** cyber governance ecosystem is one in which: (a) an audit or conformity assessment completed under one jurisdiction's framework can be read and partially relied upon by a

competent authority in another, without requiring complete re-examination; (b) an incident report filed in one framework's format can be automatically translated into the relevant fields of another framework's reporting schema, without loss of material information; (c) enforcement actions taken by one regulator do not create contradictory obligations for entities subject to another regulator's authority; and (d) an organization can produce a single, structured evidence base that satisfies the substantive requirements of multiple frameworks simultaneously, even where the frameworks use different terminology, timelines, or procedural requirements. Legibility is a property of the *interfaces* between frameworks, not of the frameworks themselves.

Legibility is emphatically not harmonization, and the distinction matters. Harmonization means identical or near-identical rules — the same definitions, the same thresholds, the same timelines, enforced by compatible institutions. Achieving harmonization across the EU, US, UK, Singapore, and the major emerging-market jurisdictions would require multilateral treaty negotiations spanning years or decades, political alignment that does not currently exist, and a sacrifice of legitimate domestic policy variation that most governments will not accept. Harmonization is the high-water ambition; legibility is what actually makes organizations more secure and regulators better informed in a world where harmonization is not imminent.

To make legibility concrete: the current situation is one where a cyber incident affecting a multinational's cloud infrastructure must be reported to the EU's relevant national CSIRT with a preliminary notification describing the nature of the incident and its initial impact assessment, then separately reported to CISA under CIRCIA's 72-hour timeline with a different data schema and different scope requirements, then assessed against Singapore's CSA notification obligations, while the organization's legal team simultaneously evaluates whether the incident implicates any sector-specific overlay. Each report is formatted differently. Each asks for different categories of information. None of the receiving regulators see each other's reports. A sophisticated attacker operating across all four jurisdictions faces a collective defense apparatus that is, by design, fragmented.

Legibility would transform this situation without requiring identical rules. A common incident classification taxonomy — agreed by participating jurisdictions, mapped against each framework's definitions — would allow an organization to file a single incident record that auto-populates the relevant fields in each jurisdiction's reporting system. A mutual recognition agreement covering audit evidence would allow an independent assessment performed to ISO 27001 or NIST CSF standards, augmented with jurisdiction-specific evidence modules, to be submitted to multiple regulators without full re-examination of the underlying evidence base. A shared indicator-of-compromise sharing protocol, operating below the level of formal incident reporting, would allow threat intelligence generated in one jurisdiction's incident response to be rapidly available to defenders in others.

Legibility requires three operational components that currently do not exist at scale: a **common taxonomy** with precise, agreed definitions of incident severity, critical infrastructure scope, and audit evidence categories; **translation interfaces** — ideally machine-readable — that map between framework requirements; and **mutual recognition agreements** at the institutional level, backed by political commitment and enforcement architecture. The third component is the

hardest to achieve and the most consequential. Without it, the first two remain academic exercises.

5. Existing Precedents That Work — and Why

The case for legibility is sometimes met with the objection that cross-framework interoperability has never been achieved in practice at the scale required. This is wrong. Several regulatory domains have achieved meaningful cross-jurisdictional legibility, and the mechanisms they used are directly applicable — with appropriate adaptation — to cyber governance. Examining what worked, and what cyber governance has failed to replicate, is more instructive than abstract institutional design.

5.1 Financial Services: The Basel and IOSCO Architecture

The Basel Committee on Banking Supervision and the International Organization of Securities Commissions (IOSCO) have spent four decades building a framework architecture that allows national banking and securities regulators to exercise meaningful mutual reliance. Basel III capital requirements are not identical across all implementing jurisdictions — the US, EU, and UK have each made national adjustments — but the core framework is sufficiently shared that a bank's capital adequacy assessment conducted in one jurisdiction is legible to supervisors in another. Regulators have developed equivalence determinations that allow home-country regulatory oversight to substitute for host-country examination in specific domains. The EU's concept of regulatory equivalence — where a third-country regulatory framework is assessed as providing equivalent protection to EU requirements — is the formal mechanism. It is imperfect and politically contested, as post-Brexit friction between the UK and EU has demonstrated. But it represents a functioning model of legibility: regulators with different rules who can read each other's conclusions.

What made this achievable in finance? Four factors stand out. First, pre-competitive industry consensus: the major financial institutions had strong, direct incentives to push for interoperability because regulatory fragmentation increased their compliance costs in ways that affected competitive position. Industry coalitions provided political energy that governments could channel. Second, technical precision in the underlying standards: capital ratios, risk-weighting methodologies, and liquidity coverage ratios are mathematically defined. There is less definitional ambiguity in "a bank must hold capital equal to 8% of risk-weighted assets" than in "an organization must implement appropriate and proportionate security measures" — which is the actual language of most cyber frameworks. Third, clear liability allocation: the Basel framework is explicit about who is responsible for what, including which regulator has primary supervisory authority over internationally active banks. Fourth, sustained political will at the level of finance ministers and central bank governors — a level of seniority that cyber governance has rarely achieved.

5.2 Aviation: ICAO Standards and Recommended Practices

The International Civil Aviation Organization's Standards and Recommended Practices (SARPs) represent perhaps the most successful example of technical regulatory legibility in the world. An aircraft certified as airworthy under US Federal Aviation Administration standards can land at airports in more than 190 ICAO contracting states because ICAO's SARPs create a shared technical baseline that national implementations are required to meet or exceed. The system works because ICAO standards are technically precise (specifying structural load tolerances, navigation system performance parameters, and maintenance interval requirements at engineering rather than policy level), because compliance is verified through a standing audit program that assesses each state's implementation, and because non-compliance has direct, concrete consequences — airlines from non-compliant states face operational restrictions. ICAO has recently extended this model to aviation cybersecurity, adopting Standards 4.9.1 and Recommended Practice 4.9.2 in Annex 17 and passing three successive Assembly resolutions (in 2016, 2019, and 2022) directing member states toward a consistent cybersecurity approach. The aviation cybersecurity SARPs are still maturing, but the institutional architecture for making them legible already exists.

5.3 Pharmaceuticals: ICH Guidelines

The International Council for Harmonisation of Technical Requirements for Pharmaceuticals for Human Use (ICH) has produced a set of technical guidelines — covering quality, safety, efficacy, and multidisciplinary topics — that are implemented by regulatory agencies in the EU, US, Japan, Canada, and Switzerland, among others. ICH guidelines do not eliminate national regulatory requirements, but they create a shared technical language that allows clinical trial data generated under one regulatory framework to be submitted to regulators in other jurisdictions. The result is that a drug developer can conduct a single suite of clinical trials whose data satisfies the substantive requirements of multiple major regulators simultaneously. The ICH model succeeded because it was driven by industry participants who had direct financial interest in eliminating duplicative trial requirements, because the underlying technical standards (biostatistical methodology, good clinical practice requirements, data reporting formats) are sufficiently precise to be machine-verifiable, and because regulatory agencies recognized that accepting each other's evidence was scientifically defensible rather than a political concession.

Key Finding: What Cyber Governance Is Missing

Comparing these precedents to the current cyber governance landscape reveals four specific absences. First, there is no pre-competitive industry consensus mechanism equivalent to what drove Basel or ICH — the major technology companies and critical infrastructure operators have not organized to demand interoperability at the level of political salience required. Second, cyber governance frameworks lack the technical precision necessary for regulatory equivalence determinations: definitions of "significant incident," "critical infrastructure," and "appropriate security measures" vary widely and are not mathematically definable in the way capital ratios or drug efficacy endpoints are. Third, liability allocation in cyber governance is deeply contested: who bears responsibility when a compliant organization is successfully attacked, or when one

regulator's enforcement action contradicts another's finding? Fourth, cyber governance has not been engaged at the level of political leadership — finance ministers, heads of state — that sustained the Basel and ICH processes through decades of difficult negotiation. Security ministers and cyber officials rarely have the durable institutional authority required.

6. A Practical Pathway Toward Legibility

The pathway we propose is deliberate in its realism. Each phase is designed to be achievable within its timeframe without depending on political conditions that do not exist. Each phase builds the foundation for the next. The overall architecture moves from the tractable — shared vocabulary — toward the ambitious — a narrow multilateral institution — while ensuring that meaningful security improvements are delivered in the near term rather than deferred to a hypothetical future.

6.1 Phase I (1–3 Years): Common Taxonomy, Evidence Standards, and Bilateral Pilots

The foundational work of legibility is taxonomic. The term "significant cyber incident" currently means materially different things under NIS2, CIRCIA, Singapore's Cybersecurity Act, and the UK's frameworks. The term "critical infrastructure" is defined differently in every jurisdiction. These definitional divergences are not primarily political disagreements — they are often historical accidents of the legislative process, or reflect genuinely different threat models that could be reconciled with modest effort. A joint technical working group, convened among the EU (through ENISA), the United States (through CISA), the UK (through the NCSC), and Singapore (through CSA), tasked with producing a common incident classification taxonomy would be a tractable near-term deliverable. The taxonomy would not replace domestic definitions; it would provide a mapping layer that translates each jurisdiction's categories into a shared reference schema. Think of it as a lingua franca for incident reports — not a new language, but a translation protocol.

Alongside the taxonomy, Phase I should establish shared minimum evidence standards for cyber audits and assessments. The question to be answered is: what categories of evidence, produced through what audit processes, are sufficient to establish that an organization has met a substantive requirement — and can that finding be relied upon by a regulator in another jurisdiction? This is exactly the question the ICH answered for pharmaceutical clinical data. The answer for cyber governance will necessarily be more contextual, but it is not unanswerable. A joint framework specifying that an ISO 27001 audit, supplemented by a jurisdiction-specific evidence module addressing the local regulatory requirements, constitutes sufficient evidence for a simplified recognition process would dramatically reduce compliance burden without sacrificing substantive oversight.

Phase I should also launch bilateral mutual recognition pilots between at least two of the major jurisdictions — most naturally the EU and UK, given their shared regulatory heritage, or the US and UK, given the depth of their existing cyber cooperation through the NCSC-CISA

relationship. A pilot would test whether a UK Cyber Essentials Plus certification, supplemented with NIS2-specific evidence, could be recognized by an EU member state CSIRT as partially satisfying NIS2 audit requirements. The pilot would generate evidence about where recognition works cleanly, where gaps exist, and what supplementary requirements are necessary — the empirical foundation for subsequent expansion.

6.2 Phase II (3–7 Years): Federated Incident Reporting and Expanded Recognition

The medium-term priority is operationalizing the taxonomy in incident reporting infrastructure. A federated incident reporting system — structured as an API layer that allows national reporting portals to automatically translate and share incident data across participating jurisdictions — would allow a single incident report filed with CISA to automatically populate the relevant fields in the ENISA CSIRT network and Singapore's CSA reporting system. The underlying data would remain subject to each jurisdiction's information handling rules; the federated system would route only the fields each jurisdiction's rules permit to be shared. This is not technically novel — it is a standard enterprise integration architecture problem — but it requires political agreement on the data standards and governance rules that the API enforces.

Expanded mutual recognition, building on the Phase I pilots, would extend bilateral agreements to a broader set of jurisdictions and begin moving toward multilateral recognition in specific, bounded domains. Critical infrastructure sectors with strong international organizations — aviation (ICAO), finance (BCBS, IOSCO), maritime (IMO), nuclear (IAEA) — are natural starting points for sector-specific interoperability agreements that leverage existing institutional relationships. A financial institution already subject to SWIFT CSCF attestation should be able to have that attestation recognized as satisfying the financial sector provisions of NIS2 and CIRCIA with supplementary evidence rather than full re-examination.

Phase II should also address the enforcement contradiction problem directly. When regulators in two jurisdictions reach conflicting findings — one finding adequate compliance, another finding material deficiency — the organization faces an impossible obligation. A conflict resolution protocol, analogous to the "lead supervisory authority" mechanism in GDPR for cross-border data processing cases, would designate a primary regulator for each entity based on factors including operational footprint, headquarters location, and materiality of operations in each jurisdiction, while preserving all regulators' rights to enforce their domestic requirements against genuine violations.

6.3 Phase III (7+ Years): A Narrow Multilateral Clearing Mechanism

The long-term architecture we propose is deliberately constrained. We are not proposing a global cyber regulator, a new treaty organization, or a replacement for domestic regulatory authority. We are proposing a clearing mechanism: a standing multilateral body with a narrow, specific mandate covering three functions. First, maintenance of the common taxonomy — an ongoing process of updating definitions as the threat environment evolves and as regulatory frameworks are revised. Second, audit recognition administration — managing the recognition agreements between participating jurisdictions, evaluating new recognition requests, and

providing a formal channel for resolving recognition disputes. Third, incident escalation — providing the institutional infrastructure for escalating cross-border incidents that exceed the capacity of bilateral coordination, analogous to the IMF's role in financial crises: not a first responder, but a backstop when bilateral channels are insufficient.

The institutional model for this mechanism is the Financial Stability Board — an international body with a focused mandate, operating by consensus among participating jurisdictions, without supranational enforcement authority but with the political legitimacy to coordinate national actions and the technical capacity to maintain shared standards. An FSB-equivalent for cyber governance would not require a new treaty; it could be established by agreement among the G7 or G20 cyber authorities and expanded through accession. It would succeed or fail based on whether participating jurisdictions found its outputs genuinely useful — which means it must be designed to serve practitioners and regulators, not to generate institutional output for its own sake.

Achieving Phase III will require political conditions that do not fully exist today. But the key insight of the phased approach is that Phase I and Phase II create the political conditions for Phase III. When EU, US, UK, and Singapore regulators have been operating a shared taxonomy for several years, when incident reports are already flowing through federated infrastructure, and when bilateral recognition agreements have demonstrated concrete compliance cost reductions, the case for a standing coordination mechanism becomes self-evidently practical rather than idealistic. The pathway builds its own momentum.

Major Cyber Governance Frameworks: Legibility Assessment

The table below maps the major frameworks discussed in this paper against four legibility criteria: definitional precision (how clearly and specifically the framework defines key terms), cross-framework translatability (whether its requirements can be mapped to those of other frameworks), audit mutual recognizability (whether assessments conducted under the framework can be relied upon by other regulators), and incident reporting interoperability (whether the framework's incident reporting architecture connects to other reporting systems).

Framework	Jurisdiction	Type	Definitional Precision	Cross-Framework Translatability	Audit Mutual Recognizability	Incident Reporting Interoperability
Budapest Convention	68 states	Treaty	Moderate (criminal offenses defined; governance	Low (criminal law focus; no	Not applicable	Low (MLAT-based; slow and bilateral)

			scope narrow)	regulatory mapping)		
UN GGE/OEWG Norms	UN membership	Non-binding norms	Low (principles-level; no operational definitions)	Very low (non-operational)	Not applicable	None
NIS2 Directive	EU	Mandatory regulation	Moderate-High (implementing acts add specificity; member state variation remains)	Moderate (references ISO 27001; NIST CSF informative)	Low (no formal recognition agreements; member state divergence)	Moderate (CSIRT network exists; no external linkages)
CIRCI	United States	Mandatory regulation	Moderate (rulemaking ongoing; definitions still being finalized)	Low (sector-specific US focus; no cross-border mapping)	None	Low (CISA internal; no international interface)
UK Cyber Essentials Plus	United Kingdom	Certification scheme	High (five precisely defined technical controls)	Moderate (maps partially to ISO 27001 baseline)	Low (no formal recognition agreements post-Brexit)	None
Singapore Cybersecurity Act	Singapore	Mandatory regulation	Moderate (amended 2024; CII definition specific; supply chain	Low (no formal cross-framework mapping)	None	Low (bilateral sharing arrangements at

			scope broadened)			intelligence level only)
NIST CSF 2.0	United States (global influence)	Voluntary framework	Moderate (outcomes-based; deliberately flexible)	High (cross-reference catalog maps to 50+ frameworks)	Low (voluntary; no enforcement ; informative only for regulators)	None
ISO/IEC 27001:2022	Global	Auditable standard	Moderate (management system requirements precise; outcome requirements minimal)	High (widely referenced by other frameworks)	Low-Moderate (widely accepted as baseline; not dispositive for mandatory compliance)	None
SWIFT CSCF	Global (financial sector)	Mandatory (sector-specific)	High (mandatory controls technically precise; architecture-dependent)	Moderate (aligned with ISO 27002, NIST CSF, PCI DSS)	Moderate (attestation visible to counterparties and supervisors)	Moderate (ISAC portal for community intelligence sharing)
IEC 62443	Global (OT/ICS sector)	Standard (increasingly mandatory)	High (security levels and technical requirements precisely defined)	Moderate (maps to ISO 27001; sector-specific)	Low (IECEE certification program exists; not cross-jurisdictionally recognized)	None

Legibility ratings are the authors' assessments based on the criteria defined in Section 4. "High" indicates the framework substantially meets the criterion; "Moderate" indicates partial satisfaction with notable gaps; "Low" indicates minimal satisfaction; "None" indicates no relevant mechanism exists.

7. Recommendations

The following recommendations are directed at specific actors, are action-specific rather than directional, and each includes a minimum viable version — the smallest step that would constitute real progress rather than process.

Recommendation 1: ENISA, CISA, NCSC, and Singapore's CSA should jointly commission a cyber incident taxonomy working group within twelve months. The working group's deliverable is a published mapping document — not a new framework — that translates the incident severity definitions, critical infrastructure scope definitions, and reporting timeline requirements of NIS2, CIRCIA, the UK's framework, and Singapore's Cybersecurity Act into a common reference schema. The minimum viable version is a bilateral EU-US taxonomy mapping, extended to include UK and Singapore in a subsequent iteration. The working group should include industry representation from at least three critical infrastructure sectors to ensure operational realism. Output should be machine-readable and published under open license to allow framework developers and compliance toolmakers to implement it.

Recommendation 2: The EU and UK should launch a formal Cyber Essentials Plus / NIS2 mutual recognition pilot within eighteen months. The pilot should test whether an organization holding current Cyber Essentials Plus certification, supplemented with a defined evidence module addressing NIS2's additional requirements (particularly supply chain security documentation and incident response plan assessment), can receive a simplified NIS2 conformity assessment without full re-examination. The minimum viable version is a pilot in one member state — the Netherlands or Ireland, both jurisdictions with deep cross-channel regulatory relationships — covering one sector. Results should be published with sufficient transparency to allow other jurisdictions to evaluate replication.

Recommendation 3: CISA should design CIRCIA's final reporting rule to include machine-readable incident data export in a format compatible with ENISA's incident reporting schema and Singapore's CSA reporting requirements. This is a design decision that can be made during the rulemaking process at minimal additional cost. The minimum viable version is a published mapping between CIRCIA's data fields and NIS2's incident notification requirements, so that covered entities operating in both jurisdictions can produce a single incident record from which both regulators' reports are generated. This does not require intergovernmental agreement on information sharing — it requires only that the data schema be designed with legibility in mind rather than as an afterthought.

Recommendation 4: The G7 cyber track should formally endorse the legibility framework and commission a feasibility study for a Phase III clearing mechanism. The G7 cyber engagement has produced useful outputs on ransomware and secure-by-design principles. The next natural step is institutional: directing finance and security ministries jointly to assess the feasibility of an FSB-equivalent for cyber governance, including governance structure, funding model, mandate scope, and relationship to existing bodies such as ENISA, CISA, and the UN's proposed Global Mechanism. The minimum viable version is a joint G7 statement directing relevant agencies to produce a feasibility report within two years — a commitment that creates accountability without prejudging the institutional outcome.

Recommendation 5: Industry coalitions in critical infrastructure sectors should fund and publish cross-framework compliance mapping tools, and advocate explicitly for legibility as a policy objective. The Basel and ICH models both required pre-competitive industry consensus as a political driver. That consensus does not currently exist in cyber governance at sufficient salience. Major technology companies, financial institutions, energy operators, and telecommunications providers all bear the compliance costs of fragmentation. A coordinated industry position — not lobbying against regulation, but specifically demanding legibility as a regulatory design requirement — would provide the political energy that government-to-government processes alone cannot generate. The minimum viable version is a cross-sector joint statement, backed by quantified estimates of compliance cost duplication, submitted to the major regulatory consultations currently underway in the EU, US, and UK.

8. Conclusion: Security Improves When Information Flows

There is a principle embedded in decades of security research that rarely receives adequate weight in governance discussions: security improves when information flows. Defenders who can share incident intelligence respond faster. Regulators who can see cross-border attack patterns detect campaigns earlier. Organizations that can compare their practices against peers improve more efficiently. This is not a controversial observation — it is the rationale behind every information sharing program, every ISAC, every coordinated vulnerability disclosure policy. What is consistently underappreciated is that governance architecture is the infrastructure that makes information flow — or prevents it.

The current state of cyber governance is a system that generates enormous quantities of compliance data while systematically preventing that data from flowing to where it would be useful. Organizations file incident reports that regulators cannot share. Audits are conducted that other regulators cannot rely upon. Definitions diverge so completely that the same attack is classified differently in different jurisdictions, and the signals that would reveal a coordinated campaign are lost in the noise of definitional inconsistency. Everyone is complying. Nobody is safer — or not as much safer as the collective investment in compliance should produce.

Legibility is the infrastructure intervention that changes this. It does not require abandoning domestic regulatory authority. It does not require resolving the deep political disagreements about state behavior in cyberspace that the UN processes have been unable to resolve for a decade. It requires something harder in its way: sustained, unglamorous technical and institutional work to build the translation layers, the evidence standards, and the recognition agreements that allow governance frameworks to read each other. That work is less visible than treaty negotiations. It does not produce headlines. But it is what would actually make organizations more secure and regulators better informed — which is, ultimately, the only standard that matters.

The Hollow House Institute offers this paper as a contribution to that work. We welcome engagement from regulators, practitioners, and researchers who are willing to move from diagnosing fragmentation to building the practical architecture of legibility.

References

- [1] European Commission. *Directive (EU) 2022/2555 of the European Parliament and of the Council on measures for a high common level of cybersecurity across the Union (NIS2 Directive)*. Official Journal of the European Union, January 2023. EUR-Lex, eur-lex.europa.eu.
- [2] European Commission. *Commission Implementing Regulation (EU) 2024/2690: Cybersecurity Risk Management Measures and Significant Incident Thresholds for Digital Service Providers*. Brussels, 17 October 2024. European Commission Press Release IP/24/5342.
- [3] Cybersecurity and Infrastructure Security Agency (CISA). *Cyber Incident Reporting for Critical Infrastructure Act of 2022 (CIRCIA): Fact Sheet*. U.S. Department of Homeland Security, 2022. cisa.gov.
- [4] CISA. *Cyber Incident Reporting for Critical Infrastructure Act (CIRCIA) Reporting Requirements: Notice of Proposed Rulemaking*. Federal Register, Vol. 89, No. 66, pp. 23644–23776. April 4, 2024. 89 FR 23644, Docket No. CISA-2022-0010.
- [5] National Institute of Standards and Technology. *The NIST Cybersecurity Framework (CSF) 2.0*. NIST Cybersecurity White Papers (CSWP) 29. Pascoe, C., Quinn, S., and Scarfone, K. Gaithersburg, MD: NIST, February 26, 2024. doi:10.6028/NIST.CSWP.29.
- [6] National Cyber Security Centre (UK). *Cyber Essentials: Requirements for IT Infrastructure, Version 3.3*. NCSC / IASME, effective April 27, 2026. ncsc.gov.uk.
- [7] Singapore Statutes Online. *Cybersecurity (Amendment) Act 2024 (No. 19 of 2024)*. Parliament of Singapore, assented May 23, 2024. sso.agc.gov.sg.
- [8] Cyber Security Agency of Singapore. *Cybersecurity Act: Overview and 2024 Amendments*. CSA Singapore, updated April 2, 2025. csa.gov.sg.
- [9] Council of Europe. *Convention on Cybercrime (Budapest Convention), ETS No. 185*. Council of Europe, opened for signature November 23, 2001. Nshimiyimana, F.R. "Adapting the Budapest Convention to Address Emerging Cyber Threats." *Belügyi Szemle*, Vol. 74, No. 1, 2026. doi:10.38146/bsz-ajia.2026.v74.i1.pp183-204.

[10] United Nations General Assembly. *Open-Ended Working Group on Security of and in the Use of Information and Communications Technologies 2021–2025: Final Report and Recommendation for a Global Mechanism*. UN Doc A/AC.290/2025. July 2025. Manohar Parrikar Institute for Defence Studies and Analyses, "UN Cyber OEWG Ends after Five-Year Run," September 2025.

[11] European Union OEWG Statement. *EU Messages for Agenda Item: Rules, Norms and Principles of Responsible Behaviour*. OEWG Ninth Substantive Session, December 2–6, 2024. Submitted on behalf of EU and Member States.

[12] International Organization for Standardization. *ISO/IEC 27001:2022 — Information Security, Cybersecurity and Privacy Protection: Information Security Management Systems — Requirements*. Third Edition. ISO/IEC JTC 1, SC 27. Geneva: ISO, October 2022.

[13] SWIFT. *Customer Security Controls Framework (CSCF) — Customer Security Programme Documentation*. SWIFT, updated annually. swift.com/myswift/customer-security-programme.

[14] International Society of Automation. *ANSI/ISA-62443-2-1-2024: Security for Industrial Automation and Control Systems*. ISA99 Standards Committee. Durham, NC: ISA, January 28, 2025. isa.org/62443standards.

[15] Bank for International Settlements — Basel Committee on Banking Supervision. *BCBS Publications Archive*. BIS, 2026. bis.org/bcbs/publications.htm.

[16] International Civil Aviation Organization. *Standards and Recommended Practices (SARPs): Annex 17 — Aviation Security, Standards 4.9.1 and Recommended Practice 4.9.2 on Aviation Cybersecurity*. ICAO Assembly Resolutions A39-19 (2016), A40-10 (2019), A41-19 (2022). [icao.int](https://www.icao.int).

[17] Glocert. *NIS2 Incident Reporting Playbook: Article 23 Timelines and CSIRT Procedures*. Technical implementation guidance. glocert.eu, 2024.

[18] Hooker, A., and Sheridan, K. "The Magnificent Seven: Exemption, Relief, Equivalence, Recognition, Substitution, Deference, Trust — Reducing Regulatory Duplication and Frictions in the Cross-Border Supply of Financial Services." *European Journal of Risk Regulation*, Vol. 15, Issue 1, March 2024, pp. 33–48. doi:10.1017/err.2023.70.

[19] OECD. *Tools for Regulatory Quality and Financial Sector Regulation: Comparative Perspectives on the Basel Committee and IOSCO Codes*. Paris: OECD, 2011. [oecd.org](https://www.oecd.org).

[20] International Society of Automation (ISA). "Update to ISA/IEC 62443 Standards Addresses Organization-Wide Cybersecurity in Industrial and Critical Infrastructure Operations." ISA Press Release, January 28, 2025. isa.org.

About the Hollow House Institute: The Hollow House Institute is an independent research organization focused on governance, technology policy, and institutional design. Our work is intended to inform practitioners, policymakers, and researchers working at the intersection of security and governance.

Licensing: This paper is published under Creative Commons Attribution 4.0 International (CC BY 4.0). Reproduction and adaptation are permitted with attribution.

Citation: Amy. (2026). *Toward Legible Cyber Governance: The Case for Harmonized Frameworks*. Hollow House Institute Policy Paper. doi:10.5281/zenodo.XXXXXXX

The views expressed in this paper are those of the author and the Hollow House Institute and do not represent the positions of any government, regulatory authority, or commercial entity.